

SSO Application – Product Requirements Document

Oct 9, 2026

Overview and problem statement

Users currently sign in separately to each internal and customer-facing application, which means many passwords, repeated login prompts, and no central place for IT to enforce access policy. This product provides Single Sign-On (SSO): one login through a central identity provider (IdP), after which users reach every connected application without re-entering credentials.

Assumption: the application serves both workforce users (employees) and admins who manage the tenant. Confirm this scope before design begins.

- Users sign in once and access all connected applications
- Administrators manage users, groups, and application access from one console
- Security teams can enforce MFA, session timeouts, and offboarding from one place

Goals, non-goals and success metrics

Goals

- Provide one login for all connected applications within the first release
- Support SAML 2.0 and OpenID Connect (OIDC) for application integration
- Let administrators provision and deprovision users automatically through SCIM 2.0

Non-goals (v1)

- Acting as a full identity provider with its own user directory for external customers
- Password manager features or browser extensions
- Hardware-token management beyond standard WebAuthn support

Success metrics (targets for the first 90 days after launch)

Metric	Target
Login success rate for SSO sign-ins	99.5% or higher

Metric	Target
Median time from IdP login to app access	Under 3 seconds
Share of connected apps using SSO	80% of in-scope apps
Support tickets about password resets	40% reduction from baseline

Users and personas

Persona	Who they are	Primary needs
End user	Employee or customer signing in to apps	One login, quick access, clear error messages
Tenant administrator	IT admin managing the organization	Add and remove apps, manage groups, audit access
Security officer	Compliance or security lead	Enforce MFA, review sign-in logs, revoke sessions
Application developer	Engineer integrating an app	Clear SDK, test tenant, straightforward configuration

Functional requirements

Authentication

1. Users sign in once at the IdP login page and are redirected back to the requested app.
2. The system supports password login plus MFA (TOTP, push, and WebAuthn).
3. Sessions expire after a configurable idle timeout (default 30 minutes) and an absolute timeout (default 12 hours).
4. Users can sign out from one app and end the SSO session everywhere (single logout).

Application management

5. Admins register an application by choosing SAML 2.0 or OIDC and entering its metadata or redirect URIs.
6. Admins assign applications to users or groups.
7. Admins can disable an application without deleting its configuration.

User and group provisioning

- 8. SCIM 2.0 creates, updates, and deactivates users in connected applications.
- 9. Deactivating a user in the directory revokes active sessions within 5 minutes.
- 10. Groups sync from the directory and drive application access.

Admin console

- 11. Dashboard shows sign-in volume, failed logins, and MFA prompts for the last 30 days.
- 12. Audit log records every admin action and sign-in event, searchable by user, app, and time range.
- 13. Exports of audit logs are available as CSV.

Self-service

- 14. Users can reset their own password and enroll MFA devices.
- 15. Users see a portal page listing the applications they can open.

Non-functional requirements

Area	Requirement
Security	All traffic over TLS 1.2 or higher; tokens signed with RS256 or ES256; keys rotated every 90 days
Performance	Sign-in redirect completes in under 1 second at p95 excluding the IdP's own latency
Availability	99.9% monthly uptime for the authentication service; 99.95% target after year one
Scalability	Supports 100,000 users and 500 connected applications per tenant
Compliance	SOC 2 Type II controls; audit logs retained for 365 days
Accessibility	Login and portal pages meet WCAG 2.1 AA
Disaster recovery	Recovery point objective of 15 minutes; recovery time objective of 1 hour

Integrations and supported protocols

Protocol or standard	Role	Version 1 scope
SAML 2.0	Application sign-on for enterprise SaaS	Yes, SP-initiated and IdP-initiated
OpenID Connect (OIDC)	Modern web and mobile applications	Yes, authorization code flow with PKCE
SCIM 2.0	User and group provisioning	Yes, users and groups
WebAuthn / FIDO2	Passwordless and hardware-key MFA	Yes
LDAP	Legacy directory lookup	No, deferred to v2
Kerberos / Windows integrated auth	On-premises desktop sign-on	No, deferred to v2

Directory sources for v1: Microsoft Entra ID and Google Workspace. Other directories are an open question (see below).

Rollout plan, risks and open questions

Rollout phases

1. **Alpha (weeks 1-4):** Internal IT team, two pilot applications, MFA enabled.
2. **Beta (weeks 5-8):** Three design partner customers, up to 20 applications.
3. **General availability (week 9):** Self-serve onboarding, full v1 scope.

Risks

Risk	Likelihood	Mitigation
Application vendors implement SAML or OIDC inconsistently	High	Ship a test harness and per-app setup guides
Lockout from MFA misconfiguration	Medium	Break-glass admin accounts and recovery codes
Directory sync delays cause stale access	Medium	Event-driven sync plus nightly reconciliation

Open questions

- ☐ Which directory sources beyond Entra ID and Google Workspace are needed for launch?
- ☐ Is the product offered to external customers, or only to workforce users?
- ☐ What is the pricing and licensing model for SCIM and audit log retention?
- ☐ Which compliance frameworks beyond SOC 2 are required in the first year?